

D332

Penetration Testing and Vulnerability Analysis

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word _____	The one fact that decides _____	Answer _____	[] sure [] unsure [] guess
-----------------------------	---	------------------------	----------------------------------

Items

1.

A security consultant with ten years of experience is hired by a regional credit union. The IT director, who has been with the credit union since it opened, says on a phone call, "Go ahead and start Monday." The statement of work and rules of engagement are still waiting for the CEO's signature. What should the consultant do on Monday?

- A. Start testing, because the IT director gave verbal approval.
- B. Start with low-impact tests only, and save the rest for after the signature.
- C. Wait to begin any testing until the signed authorization is in hand.
- D. Start, since the director's long tenure gives him the authority.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2. [TRANSFER — reversed stem / different variable]

A tester has a signed rules-of-engagement document. Which situation would require stopping and going back to the client before continuing?

- A. The tester documents findings on an in-scope server.
- B. The client asks mid-test to add a new office network that is not in the signed document.
- C. The tester finishes an in-scope task earlier than the planned window.
- D. Every finding of any kind requires stopping and re-authorizing.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

The signed scope for a retail chain lists its three web servers and its internal HR system. During planning, the tester notices that the web servers pull product images from a separate content delivery service run by an outside vendor. The retail chain's marketing team is very proud of the new site design. May the tester include the vendor's service in testing?

- A. Yes, because the marketing team wants the new site checked.
- B. Yes, because the in-scope servers depend on it.
- C. No; it is out of scope unless the vendor and client authorize it in writing.
- D. Yes, as long as the testing is done only during business hours.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4.

Before any contact with the client's network, a tester reads the company's public job postings, which mention the database product it uses, and reviews its public DNS records through a third-party lookup site. The client is a mid-sized logistics firm with offices in four states. How are these activities classified?

- A. Vulnerability identification.
- B. Out of scope, because the firm operates in several states.
- C. Active information gathering.
- D. Passive information gathering.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5. [TRANSFER — reversed stem / different variable]

Which activity is an example of active information gathering?

- A. Reviewing employee profiles on a professional networking site.
- B. Running an authorized scan that sends requests to the client's in-scope servers to see which services respond.
- C. Searching a public certificate log for the client's domain names.
- D. Reading the client's annual report.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

A hospital's compliance officer receives a 40-page automated scanner report listing 212 possible weaknesses. The scan ran overnight on a weekend and finished in six hours. She asks whether the hospital now knows which weaknesses an attacker could actually use. What is the best answer?

- A. Not yet; the scan lists likely weaknesses, and a penetration test or manual validation is needed to confirm which are real and usable.
- B. Yes; every item on the report has been confirmed as usable.
- C. Yes, because the scan ran long enough to be complete.
- D. No, because a scan only covers physical security.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7.

An IT team runs two scans of the same 50 workstations. The first scan runs without logging in; the second uses a read-only admin account. The team lead prefers dark mode in the scanner console. Which result is most likely?

- A. Both scans find exactly the same results.
- B. The credentialed scan fixes the missing patches automatically.
- C. The non-credentialed scan finds more, because it sees what an outsider sees.
- D. The credentialed scan finds more missing patches and has fewer false positives.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8.

A scanner reports that a file server runs an outdated, vulnerable version of a web service. The engineer, who built the server last spring, checks it directly and finds that no web service is installed at all. What is this finding?

- A. A false positive.
- B. A true positive.
- C. A zero-day vulnerability.
- D. A false negative.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9. [TRANSFER — reversed stem / different variable]

A server has a known, unpatched weakness, but the scanner report does not mention it. What is this?

- A. A false negative.
- B. A true negative.
- C. An accepted risk.
- D. A false positive.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10.

A test finds two issues. Issue A scores 9.1 on an internal lab server with no sensitive data and no internet access. Issue B scores 7.4 on the public payment page that handles card data. The report was delivered two days early. Which should the team fix first?

- A.** Issue A, because 9.1 is higher than 7.4.
- B.** Issue A, since an early report means the scores are more accurate.
- C.** Issue B, because the system is exposed and business-critical.
- D.** Neither until both have the same score.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

A tester is writing the final report for a school district. The superintendent and board will read the opening section; the district's two network engineers will fix the issues. The testing ran for three weeks in the summer. What belongs in the executive summary?

- A.** Full scanner output and command logs for every finding.
- B.** The overall risk level, the most serious business impacts, and the top recommended actions in plain language.
- C.** Only the number of findings, with no descriptions.
- D.** A day-by-day diary of the three-week test.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12. [TRANSFER — reversed stem / different variable]

Which item belongs in the technical findings section rather than the executive summary?

- A.** A one-paragraph statement of overall business risk.
- B.** A chart of risk by business unit for the board.
- C.** A recommendation to raise the security budget next year.
- D.** Evidence of each finding and step-by-step remediation guidance for the affected systems.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer C Concept 1

A security consultant ~~with ten years of experience~~ is hired by a regional credit union. The IT director, ~~who has been with the credit union since it opened,~~ says on a phone call, "Go ahead and start Monday." The statement of work and rules of engagement are still waiting for the CEO's signature. What should the consultant do on Monday?

Target word: when testing may begin **Decides:** The signed authorization is not complete.

A	Dropped element	Drops the requirement that approval be written and signed.
B	Adjacent category	Any active testing, however gentle, still needs authorization.
C	Correct	Written sign-off from an authorized owner is the legal and ethical gate for any testing.
D	Camouflage	Tenure does not replace the signed documents the stem says are still pending.

2. Answer B Concept 1 • transfer

A tester has a signed rules-of-engagement document. Which situation would require stopping and going back to the client before continuing?

Target word: what falls outside existing authorization **Decides:** Authorization covers only what the document describes.

A	Inverted operation	Documenting in-scope findings is the job, not a trigger to stop.
B	Correct	New targets need a written amendment before they are tested.
C	Confusion set	Finishing early stays inside the approved scope and schedule.
D	Absolute language	Only changes to scope, method, or critical-risk events trigger escalation.

3. Answer C Concept 2

The signed scope for a retail chain lists its three web servers and its internal HR system. During planning, the tester notices that the web servers pull product images from a separate content delivery service run by an outside vendor. ~~The retail chain's marketing team is very proud of the new site design.~~ May the tester include the vendor's service in testing?

Target word: whether a connected third-party system is in scope **Decides:** The vendor's service is not listed in the signed scope.

A	Camouflage	Enthusiasm for the site does not change what is authorized.
B	Adjacent category	A dependency does not make a system in scope.
C	Correct	Scope is defined by the signed list, and a third party must approve testing of its own systems.
D	Dropped element	Timing rules do not replace the missing authorization.

4. Answer D Concept 3

Before any contact with the client's network, a tester reads the company's public job postings, which mention the database product it uses, and reviews its public DNS records through a third-party lookup site. ~~The client is a mid-sized logistics firm with offices in four states.~~ How are these activities classified?

Target word: passive or active **Decides:** Nothing was sent to the client's own systems.

A	Confusion set	That later phase tests for specific weaknesses; this is still reconnaissance.
B	Camouflage	Office locations do not decide the classification.
C	Inverted operation	Active gathering sends traffic to the target; none was sent here.
D	Correct	Public sources and third-party lookups do not touch the target.

5. Answer B Concept 3 • transfer

Which activity is an example of active information gathering?

Target word: pick the active example **Decides:** Active means sending traffic to the target itself.

A	Adjacent category	Public social information is passive open-source research.
B	Correct	Sending traffic to the target makes it active.
C	Confusion set	Third-party public records do not touch the target.
D	Inverted operation	Public documents are passive sources.

6. Answer A Concept 4

A hospital's compliance officer receives a 40-page automated scanner report listing 212 possible weaknesses. ~~The scan ran overnight on a weekend and finished in six hours.~~ She asks whether the hospital now knows which weaknesses an attacker could actually use. What is the best answer?

Target word: what a scan proves **Decides:** A scan detects possible weaknesses; it does not confirm them.

A	Correct	Scanning identifies; testing confirms exploitability and impact.
B	Absolute language	Scanners produce false positives and do not prove impact.
C	Camouflage	Run time does not turn detection into confirmation.
D	Confusion set	Vulnerability scans cover systems and software, not physical security.

7. Answer D Concept 5

An IT team runs two scans of the same 50 workstations. The first scan runs without logging in; the second uses a read-only admin account. ~~The team lead prefers dark mode in the scanner console.~~ Which result is most likely?

Target word: which scan finds more accurate results **Decides:** The second scan is credentialed.

A	Absolute language	Access level changes what the scanner can see.
B	Adjacent category	Scanning reports weaknesses; patching is a separate remediation task.
C	Inverted operation	The outside view is narrower and relies on guessing from responses.
D	Correct	Logging in lets the scanner read installed versions and settings directly.

8. Answer A Concept 6

A scanner reports that a file server runs an outdated, vulnerable version of a web service. The engineer, ~~who built the server last spring,~~ checks it directly and finds that no web service is installed at all. What is this finding?

Target word: classify the finding **Decides:** The tool reported a weakness that does not exist.

A	Correct	The tool flagged something that is not actually present.
B	Confusion set	A true positive would be confirmed on inspection; this was not.
C	Adjacent category	A zero-day is an unknown flaw with no fix, not a scanner error.
D	Inverted operation	A false negative is a real weakness the tool missed.

9. Answer A Concept 6 · transfer

A server has a known, unpatched weakness, but the scanner report does not mention it. What is this?

Target word: name the missed-detection error **Decides:** A real weakness was not reported.

A	Correct	A real problem the tool failed to report.
B	Confusion set	A true negative means no weakness exists and none was reported.
C	Adjacent category	Risk acceptance is a management decision, not a detection error.
D	Inverted operation	That would be a reported problem that is not real.

10. Answer C Concept 7

A test finds two issues. Issue A scores 9.1 on an internal lab server with no sensitive data and no internet access. Issue B scores 7.4 on the public payment page that handles card data. ~~The report was delivered two days early.~~ Which should the team fix first?

Target word: remediation order **Decides:** Issue B sits on a critical, exposed system handling sensitive data.

A	Dropped element	Uses the score alone and drops asset criticality and exposure.
B	Camouflage	Delivery timing has nothing to do with priority.
C	Correct	Priority weighs score with asset value and exposure.
D	Absolute language	Scores do not need to match to set priority.

11. Answer B Concept 8

A tester is writing the final report for a school district. The superintendent and board will read the opening section; the district's two network engineers will fix the issues. ~~The testing ran for three weeks in the summer.~~ What belongs in the executive summary?

Target word: content of the executive summary **Decides:** The readers are leadership, not engineers.

A	Adjacent category	That belongs in the technical appendix for engineers.
B	Correct	Executives need risk and decisions, not technical detail.
C	Dropped element	A count alone gives no sense of risk or action.
D	Camouflage	The testing timeline does not tell leaders what to decide.

12. Answer D Concept 8 · transfer

Which item belongs in the technical findings section rather than the executive summary?

Target word: pick technical-section content **Decides:** Technical section = evidence and exact fix steps for engineers.

A	Inverted operation	That is executive summary content.
B	Adjacent category	A board-level view, not engineering detail.
C	Confusion set	A strategic decision for leadership.
D	Correct	Engineers need proof and specific fix steps.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owned.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	4	
Wrong stem number	A figure copied from the prompt that is not the answer.	0	
Adjacent category	The right idea in the wrong bucket.	8	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	7	
Absolute language	Always, never, guarantee — where judgment applies.	4	
Confusion set	Every option is real; the test is exact role-matching.	7	
Camouflage	Answers a stem fact that was never the question.	6	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Written authorization first	No testing begins until the system owner signs off in writing; verbal approval or good intent is not authorization.	Assuming a manager's hallway approval or a good cause is enough to start.	Testing is about to start and the paperwork is not mentioned or is incomplete.
2	Scope boundaries	Only systems listed in the signed scope may be tested; anything else, even if reachable or related, is out of bounds.	Testing a connected third-party or cloud host because it is 'part of the same network'.	A system appears that is not on the approved list.
3	Passive vs. active information gathering	Passive gathering uses public sources without touching the target; active gathering sends traffic to the target.	Calling any research 'passive' because it happens early.	Whether anything was sent to the target's systems.
4	Vulnerability scan vs. penetration test	A scan identifies and lists likely weaknesses; a penetration test confirms whether they can actually be used and what impact follows.	Treating a scanner report as proof of exploitability.	The question asks whether a weakness was confirmed or only detected.
5	Credentialed vs. non-credentialed scans	Credentialed scans log in and see installed software and configuration, giving fewer false positives and more complete findings.	Thinking an unauthenticated outside view is the more thorough scan.	Missing patch or configuration details that only an inside view could reveal.
6	False positives vs. false negatives	A false positive reports a weakness that is not there; a false negative misses one that is there.	Swapping the two terms.	A finding that manual validation contradicts, or a known weakness the tool did not report.
7	Risk-based prioritization	Remediation order weighs severity score together with asset criticality and exposure, not the score alone.	Fixing strictly in descending CVSS order regardless of which system is affected.	Two findings with different scores on systems of different importance.
8	Reporting for the audience	The executive summary states business risk in plain terms; technical findings give evidence and remediation steps for engineers.	Putting raw tool output in the executive summary.	Who the reader is: leadership or the remediation team.

Course scope (public description): Penetration Testing and Vulnerability Analysis introduces learners to the skills necessary to perform penetration testing and vulnerability management within an organization. The course covers widely used penetration testing techniques and tools that focus on planning and scoping, information gathering, vulnerability identification, and attacks and exploits. In addition, it offers hands-on experience and a focus on penetration testing engagement plans.